

Network Administration / System Administration

Homework 10

Student: 吳亞倫
ID: B13901011
Department: 電機工程學系

Discussion Partners:

- Classmates：賴泓安、鄭竣陽、喻慈恩

A. Miscs

Reference:

- [WiFi 網路的識別: BSS, ESS, SSID, ESSID, BSSID](#)
- [What is difference among SSID, BSSID and ESSID?](#)

Problem 1.

- SSID (Service Set Identifier) 是無線網路的「服務設定識別碼」，即你在裝置上看到、用來連線的網路名稱。它是一組長度最多 32 個字元的字串，用來區分不同的無線網路。同一個 SSID 下的裝置會在同一個 WLAN 中進行通訊。
- 而 BSSID (Basic Service Set Identifier) 是無線網路的「基本服務設定識別碼」，即用來分辨每一個 AP 的唯一識別碼。通常是 AP 的 MAC 位址。當有多個 AP 使用同一個 SSID 時，每個 AP 都會有不同的 BSSID，用來區分裝置現在是連到哪一個 AP。
- 一個 SSID 可以有多個 AP 來提供 WiFi 服務，因此會有多個 BSSID。使用者決定要連接哪一個 SSID 的 WiFi 之後，裝置之間會自動選擇最適合的 AP 來連接。這樣的架構可以讓使用者在不同的地點都能夠連接到同一個 SSID 的 WiFi，而不需要手動切換 AP。

Problem 2.

- 同一個 AP 可以同時有很多 SSID，而同一個 SSID 也可以同時有很多 AP。
- 舉例來說，資工系上的 WiFi 具有兩個 SSID，分別是 csie 和 csie-5g，提供了不同頻段的 WiFi 服務。這兩個 SSID 的 WiFi 都是由同一個 AP 提供的，並且可以同時存在於同一個 AP 上。同時，為了提供更好的無線網路覆蓋範圍，資工系的 WiFi 也會在不同區域設置多個 AP，每個 AP 都會有自己的 BSSID，但共用同一個 SSID。這樣的架構可以讓使用者在不同的地點都能夠連接到同一個 SSID 的 WiFi，而不需要手動切換 AP。

B. HTML' s Wi-Fi Problem

Reference:

- Friis transmission equation
- 分貝
- Signal-to-interference-plus-noise ratio

Problem 1. 根據 Friis transmission equation，在 P_t , G_t , G_r , d 皆相同的情況下，我們可以得知收到的訊號強度與波長平方成正比，即 $P_r \propto \lambda^2$ 。由於頻率與波長成反比，因此 2.4 GHz 的 Wi-Fi 頻率較 5 GHz 的 Wi-Fi 頻率波長長，故 2.4GHz 的 Wi-Fi 接收訊號強度較高。

Problem 2.

- 首先，將題目給的 $G_{t,db}$ 和 $G_{r,db}$ 換算回成線性增益 G_t 和 G_r ：

$$G_t = 10^{\frac{G_{t,db}}{10}} = 10^0 = 1, \quad G_r = 10^{\frac{G_{r,db}}{10}} = 10^0 = 1$$

- 帶入 Friis transmission equation，其中 $c = 3 \times 10^8$ m/s 為光速：

$$\begin{aligned} P_r/P_t &= G_t G_r \cdot \frac{\lambda^2}{(4\pi d)^2} = G_t G_r \cdot \frac{(\frac{c}{f})^2}{(4\pi d)^2} \\ &= 1 \times 1 \times \frac{(3 \times 10^8)^2}{(4\pi \times 1 \times 5 \times 10^9)^2} \\ &= 2.2797 \times 10^{-5} \\ &= -46.42 \text{ dB} \end{aligned}$$

Problem 3.

(a) 新 AP 設置前：

- 教授與 R103-front 之間的距離 $d_{\text{front}} = \sqrt{5^2 + 20^2} = \sqrt{425} \approx 20.62$ m
- 教授與 R103-rear 之間的距離 $d_{\text{rear}} = \sqrt{25^2 + 10^2} = \sqrt{725} \approx 26.93$ m
- 由於教授距離 R103-front 較近，因此會優先連接 R103-front。視 Front 的強度為訊號強度 S ，Rear 的強度為干擾強度 I 。SINR 根據定義為 S/I ，帶入公式如下：

$$\text{SINR} = P_{r,\text{front}}/P_{r,\text{rear}} = \left(\frac{d_{\text{rear}}}{d_{\text{front}}}\right)^2 = \left(\frac{725}{425}\right) \approx 1.71 \approx 2.3 \text{ dB}$$

(b) 新 AP 設置後：

- 教授新的 AP 的距離為 $d_{\text{new}} = 5$ m

- 教授距離新 AP 的距離 d_{new} 較近，因此會優先連接新 AP。因此視新 AP 的強度為訊號強度 S ，R103-front 和 R103-rear 的強度和為干擾強度 I 。因此，SINR 為：

$$\text{SINR} = P_{r,\text{new}} / (P_{r,\text{front}} + P_{r,\text{rear}}) = \left(\frac{d_{\text{new}}^{-2}}{d_{\text{front}}^{-2} + d_{\text{rear}}^{-2}} \right) = \frac{1/25}{1/425 + 1/725} = 10.717 \approx 10.3\text{dB}$$

我們可以發現增加新的 AP 之後，SINR 從約 2.3 dB 提升到約 10.3 dB，的確可以有效的提升教授的 Wi-Fi 連線品質。

C. Tiaosu' s Hotspot

Reference:

- [Arch Wiki: Software access point](#)
- <https://moda.gov.tw/press/multimedia/blog/11728>
- [從加密技術看無線網路安全](#)
- [Aircrack-ng 破解 WEP 加密 Wi-Fi 密碼](#)
- [WiFi 四次握手分析](#)
- [What is a deauthentication attack, and how does it work?](#)
- [什麼是 KRACK 攻擊？| 如何防禦 KRACK 攻擊](#)

C.1. Gimme expensive French meal

Problem 1.

- 我假設 WiFi 的 interface 是 wlan0，橋接的 interface 是 br0。
- 我選擇使用 channel 6，即 2437 MHz 的頻道，因為這是最常用的頻道之一，且滿足中華民國 2.4 - 2.4835 GHz 的頻道規範。
- 我的設定檔案如下：

```

1 # /etc/hostapd/hostapd.conf
2
3 interface=wlan0
4 driver=nl80211
5 bridge=br0
6
7 ssid=tiaosu
8 hw_mode=g
9 channel=6
10 country_code=TW
11
12 macaddr_acl=0
```

```

13 auth_algs=2
14 wpa=3
15 wep_key0=xxxxxxxxxx
16 wep_tx_keyidx=0

```

C.2. WEP is dangerous!

Problem 2.

- **Open System Authentication:**

在此種方式當中，Client 會對先 AP 送出 Authentication Request。而 AP 在收到之後，都會回覆一個 Authentication Response。這個方式的認證過程是沒有任何的加密的，這意味著任何人都可以連接到 AP 上。

- **Shared Key Authentication:**

在此種方式當中，會透過一個稱之為 challenge 的隨機字串來進行認證。首先，Client 會對 AP 送出 Authentication Request。AP 在收到之後，會回覆一個明文的 challenge 字串。接著，Client 會用事先共用的 WEP 金鑰加密該 challenge，並回傳給 AP。AP 會用相同金鑰解密，若解出來的明文與原始 challenge 相符，則回傳 Authentication Success，否則回傳失敗。相較於 Open System Authentication，這種方式的認證過程是有加密的，但仍然存在一些安全性問題。例如，共用金鑰洩漏的可能性極高。

Problem 3.

- 第 11 筆封包看到 Client 對 AP 發送 Shared Key 的 Authentication Request，但是在第 13 筆封包中 AP 回覆 Responding STA does not support the specified authentication algorithm，這表示 AP 不支援 Shared Key 的認證方式，因此 Client 無法連接到 AP。
而在後續 15 筆封包中，Client 對 AP 發送 Open System 的 Authentication Request，在第 17 當中 AP 回覆 Authentication Success，表示 Client 成功連接到 AP。
- 在這過程當中，攻擊者一般使用 ARP 協定，進行稱為 ARP Replay Attack 的攻擊方式。攻擊者會重複 replay 搜集到的 ARP 封包，並且將其發送到 AP 上。每次重播都會被 AP 重新加密並分配新的 IV，攻擊者便能快速蒐集到大量 IV，並且用來破解 WEP 金鑰。
- 在安裝完 aircrack-ng 之後，我們可以使用指令 aircrack-ng WEPCapture.cap 來破解 WEP 金鑰。執行完後出現以下的結果：

```

1 KEY FOUND! [ 63:73:6C:3C:33 ] (ASCII: cs1<3 )

```

```

Aircrack-ng 1.7

[00:00:01] Tested 315125 keys (got 2453 IVs)

KB  depth  byte(vote)
0  18/ 31  63(3328) 27(3328) 37(3328) 5C(3328) 93(3328) EB(3328) 9A(3328) 92(3328) FD(3328) 43(3328)
1  1/  4   73(4608) 1D(4352) 3F(4352) 0E(4096) A5(4096) 80(4096) D5(4096) 0A(4096) B1(3840) 4A(3840)
2  1/ 11   6C(5328) C0(4864) B4(4864) 5F(4608) B8(4608) D1(4608) D8(4608) C4(4096) 20(4096) 5E(4096)
3  18/ 14   1D(4096) CC(3840) 7E(3840) 04(3840) 77(3840) 9B(3840) 2F(3840) B5(3840) E2(3584) A5(3584)
4  11/ 17   33(4096) BA(3840) 4B(3840) 68(3840) E4(3840) EA(3584) 6A(3584) F6(3584) B5(3584) 23(3584)

KEY FOUND! [ 63:73:6C:3C:33 ] (ASCII: cs1<3 )
Decrypted correctly: 100%

~/codes/NTUEE/NASA/homework10/cap main 12 73 >

```

Figure 1: Aircrack-ng 破解 WEP 金鑰

- (d) 進入 Preference > Protocols > IEEE 802.11 > Decryption Keys，並且新增一個 key type 為 WEP，Key 為 63:73:6C:3C:33 的金鑰。解密後，可以在第 24276 筆封包看到 client 對 server (IP 和 Port 為 140.112.30.188:54321) 發出請求，並且以 username: tiaosu 和 password: ilovecsl 登入。在第 24300 筆封包中，server 回覆 client 包含 flag 的回應，如下所示：

```

1 Login successful! Although this is HTTP but WEP is so safe so I'll send the
  ↪ flag to you directly!!! NASA_HW10{W3P_15_N07_50_54F3}

```

Problem 4. WEP 的確很容易被破解並且截取當中的封包內容。然而，若網站是透過 https 加密的，則 WEP 封包被破解之後，依然有一層 TLS 的加密保護。這樣的話，攻擊者就無法直接看到封包內容，因為 TLS 會對傳輸的資料進行加密和驗證，即使攻擊者能夠截取到 WEP 封包，他們仍然需要破解 TLS 的加密才能獲取實際的資料內容。因此，WEP 雖然不安全，但如果網站使用 HTTPS 加密，則可以有效地保護資料的安全性。

C.3. I must get free hotspot

Problem 5. 四次握手的核心目標是為了生成一個用來加密無線通訊的密鑰，並且確保雙方都擁有相同的密鑰。以下為我的四向交握循序圖：

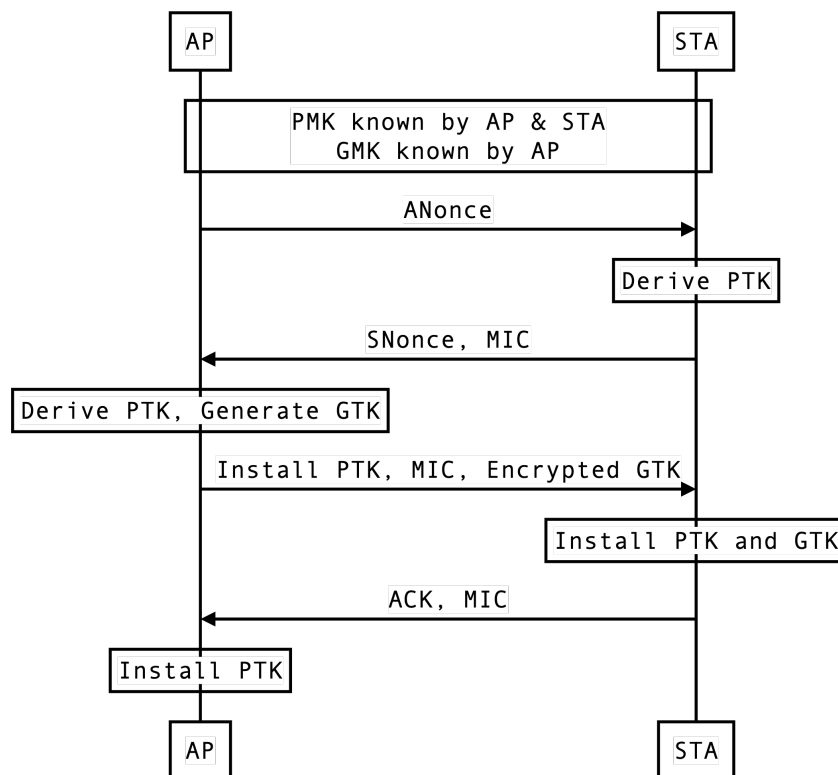


Figure 2: 四向交握循序圖

Problem 6. Deauthentication Attack 是一種透過發送 Deauthentication 封包來斷開 Client 與 AP 之間的連線的攻擊方式，透過強迫 Client 重新連接到 AP，從而捕獲四次握手的封包。攻擊者就可以透過這些封包取得 ANonce、SNonce 和 MIC 等等資料，並且嘗試破解密碼。這種攻擊方式的原理是利用了 Wi-Fi 的設計缺陷，因為 Wi-Fi 協定並沒有對 Deauthentication 封包進行驗證，因此攻擊者可以輕易地偽造這些封包。

Problem 7.

- (a) 根據封包內容，可以判斷 AP 的 MAC 位址為 2C:CF:67:57:78:33，而 Client 的 MAC 位址為 BA:E0:E8:E8:4F:41。
- (b) 第一次握手的封包為第 21 筆封包。

19	2.900192	RaspberryPi_57:78:33	ba:e0:e8:e8:4f:41	802.11	93 Association Response, SN=3725, FN=0, Flags=.....
20	2.900362		RaspberryPi_57:78:33	802.11	10 Acknowledgement, Flags=.....
21	2.904543	RaspberryPi_57:78:33	ba:e0:e8:e8:4f:41	EAPOL	133 Key (Message 1 of 4)
22	2.904752		RaspberryPi_57:78:33	802.11	10 Acknowledgement, Flags=.....
23	2.926367	ba:e0:e8:e8:4f:41	RaspberryPi_57:78:33	EAPOL	157 Key (Message 2 of 4)
24	2.926600		ba:e0:e8:e8:4f:41	802.11	10 Acknowledgement, Flags=.....
25	2.928484	RaspberryPi_57:78:33	ba:e0:e8:e8:4f:41	EAPOL	157 Key (Message 3 of 4)
26	2.928858		RaspberryPi_57:78:33	802.11	10 Acknowledgement, Flags=.....
27	2.933998	ba:e0:e8:e8:4f:41	RaspberryPi_57:78:33	EAPOL	133 Key (Message 4 of 4)
28	2.934154		ba:e0:e8:e8:4f:41	802.11	10 Acknowledgement, Flags=.....
29	2.937027	RaspberryPi_57:78:33	ba:e0:e8:e8:4f:41	802.11	185 QoS Data, SN=2, FN=0, Flags=.p....F.

Figure 3: 第一次握手的封包

- (c) 透過使用 eapol 作為過濾條件，可以找到四次完整的四次握手封包。



No.	Time	Source	Destination	Protocol	Length	Info
21	2.904543	RaspberryPi_57:78:33	ba:e0:e8:e8:4f:41	EAPOL	133	Key (Message 1 of 4)
23	2.926367	ba:e0:e8:e8:4f:41	RaspberryPi_57:78:33	EAPOL	157	Key (Message 2 of 4)
25	2.928484	RaspberryPi_57:78:33	ba:e0:e8:e8:4f:41	EAPOL	157	Key (Message 3 of 4)
27	2.933998	ba:e0:e8:e8:4f:41	RaspberryPi_57:78:33	EAPOL	133	Key (Message 4 of 4)

Figure 4: 四次握手的封包

- (d) 我使用以下指令進行四次握手的解密，得到密碼為 felwinter。

```
1 aircrack-ng -w rocktiaosu.txt -b 2C:CF:67:57:78:33 DeAuthCapture.cap
```

```

[00:32:11] 12109551/14344392 keys tested (6177.00 k/s)

Time left: 6 minutes, 1 second                                84.42%

KEY FOUND! [ felwinter ]

Master Key      : 00 9C 4C 3F 61 98 5F 1D BE 96 78 EC C3 AC 9F 5C
                  5E 8E 83 85 65 7B C9 95 3B FB 5B C2 5B 27 C0 2C

Transient Key   : 6A CE C2 2B 1F 5A C2 6E A1 11 A8 B4 E9 34 03 B2
                  C5 F0 74 9F B4 9A 0B 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

EAPOL HMAC     : E8 EB 69 68 A2 6C 38 03 2E F1 7F 56 57 77 75 D5

~/codes/NTUEE/NASA/homework10/cap main !2 ?1 > █

```

Figure 5: 破解 passphrase

- (e) 進到 Preferences > Protocols > IEEE 802.11 > Decryption Keys，新增一個 key type 為 WPA-PWD，Key 為 felwinter 的金鑰。解密後，可以在第 43 筆封包看到 DHCP ACK 的封包，給予 Client IP 位址為 192.168.0.81。

dhcp							
No.	Time	Source	Destination	Protocol	Length	Info	
40	3.059096	0.0.0.0	255.255.255.255	DHCP	384	DHCP Request	- Transaction ID 0xea108ef9
42	3.062921	0.0.0.0	255.255.255.255	DHCP	382	DHCP Request	- Transaction ID 0xea108ef9
43	3.062926	192.168.0.1	192.168.0.81	DHCP	382	DHCP ACK	- Transaction ID 0xea108ef9
5085	24.799818	0.0.0.0	255.255.255.255	DHCP	384	DHCP Request	- Transaction ID 0x3db1f430
5087	24.803469	0.0.0.0	255.255.255.255	DHCP	382	DHCP Request	- Transaction ID 0x3db1f430
5090	24.805881	192.168.0.1	192.168.0.81	DHCP	382	DHCP ACK	- Transaction ID 0x3db1f430
9177	37.911568	0.0.0.0	255.255.255.255	DHCP	384	DHCP Request	- Transaction ID 0xa515a5a8
9179	37.915203	0.0.0.0	255.255.255.255	DHCP	382	DHCP Request	- Transaction ID 0xa515a5a8

Figure 6: DHCP ACK 的封包

Problem 8. KRACK attack 主要是用來針對 WPA2 的漏洞進行攻擊。為了更快地重新連線，Wi-Fi 在重連時只需要重新傳輸四次握手的第三部分。

攻擊者只要攔截並重放這個第三次握手封包，就能誘使客戶端重複安裝同一把 PTK 並重置內部的 Nonce，導致 keystream 重複使用。如此一來，攻擊者便可以利用已知的明文-密文對來解密後續封包，或偽造惡意封包，達到竊聽和中間人攻擊的目的。